

SyDent — وثيقة تسليم المشروع للمبرمج

تاريخ الوثيقة: ٢٧ حزيران ٢٠٢٦

آخر إصدار من الكود (HEAD): 3992bf6

رابط الموقع المباشر: <https://sydent.app>

الحالة: المنتج شغال ومنشور، بدون أي عميل حقيقي بعد (كل البيانات تجريبية). جاهز ليستلمه مبرمج محترف ويكمل تسليم ما قبل الإطلاق.

مين كتب هالوثيقة وليفش: المالك الأصلي (د. أيهم غنيم) طبيب أسنان مو مبرمج. بنى SyDent بمساعدة الذكاء الاصطناعي، وعم يسلم الكود كامل لمبرمج محترف. هاي الوثيقة هي خريطة التوجيه: شو هو النظام، كيف بيشتغل، بأي حالة هو، وشو بالضبط ضل قبل استقبال أول عميل مدفوع.

١. شو هو SyDent

نظام SaaS متعدد المستأجرين لإدارة عيادات الأسنان موجّه للسوق السوري/العربي. كل طبيب (عيادة) ييسجل ويباخذ مساحة عمل معزولة خاصة فيه. وفي كمان طبقة إدارة المنصة للمالك يدير منها كل العيادات (الاشتراكات، الخطط، الفوترة).

• **الواجهة:** عربي كامل، من اليمين لليساار (RTL)، خط Cairo، ثيم داكن + وضع فاتح، PWA (قابل للتثبيت كتطبيق).
• **طبقتان:**

• **طبقة المستأجر (Tenant) —** ٢١ صفحة HTML للعيادات، كل عيادة معزولة عبر Row-Level Security بقاعدة البيانات (`owner_id = auth.uid()`).

• **طبقة المنصة (Platform) —** `admin.html` ، إدارة SaaS بمستوى احترافي (مبنية على أنماط Stripe و Microsoft Partner Center).

• **صفحة عامة مستقلة:** `book.html` — بوابة حجز إلكترونية للزوار المجهولين. **تُعامل كملف محمي مستقل — لا يُمسس أبداً أثناء التعديلات الجماعية على باقي الصفحات.**

٢. التقنيات المستخدمة (Tech Stack)

الطبقة	التقنية
الواجهة الأمامية	HTML/CSS/JS — بدون أدوات بناء، بدون إطار عمل، بدون bundler. كل صفحة ملف <code>.html</code> مستقل فيه JS مضمّن.
الوحدات المشتركة	<code>timepicker.js</code> , <code>theme.js</code> / <code>theme.css</code> , <code>sidebar.js</code> , <code>supabase-init.js</code>
الخلفية (Backend)	Supabase — PostgreSQL + Row-Level Security + Auth + Storage + دالة Edge واحدة
الاستضافة والنشر	Cloudflare Pages، نشر تلقائي من فرع <code>main</code> على GitHub عند كل push
إدارة الإصدارات	GitHub: <code>AyhamGhnaim/SyDent</code> ، الفرع <code>main</code>
البريد الإلكتروني	Resend عبر custom SMTP (النطاق <code>mail.sydent.app</code>)، مربوط بـ Supabase Auth
المراقبة	Sentry + BetterStack (uptime) (أخطاء JS)
النسخ الاحتياطي	GitHub Actions ← نسخة قاعدة بيانات لريبو خاص + ملفات المرضى لـ Cloudflare R2

مهم: المنتج المنشور هو الكود **الصّرف (HTML/JS)** بجذر الريبو. ما في خطوة compile — عدّل ملف `.html` / `.js` ،
اعمل push لـ `main` ، و Cloudflare Pages ينشره. (راجع القسم ١١ للملفات القديمة التي **ليست** جزءاً من الإنتاج.)

٣. بنية الريبو

```

/ (جذر الريبو)
├── *.html                ← (العامة book.html + ٢١ للمستأجر/الأدمن) ٢٢ صفحة
├── supabase-init.js      ← بوابة الدخول، نظام القفل، شريط انقطاع النت، Supabase مشترك: تهيئة
├── sidebar.js            ← مشترك: التنقل + حجب الخطط
├── theme.css / theme.js  ← مشترك: الثيمات (داكن/فاتح)
├── timepicker.js         ← مشترك: منتقي وقت مخصّص ١٢ ساعة
├── manifest.json, favicon.svg, robots.txt, sitemap.xml ← PWA / SEO
├── migrations/           ← للترحيلات (راجع القسم ٥ - سجلّ جزئي، اقرأ التنبيه) SQL ملفات
├── supabase/functions/admin-ops/index.ts ← الوحيدة (عمليات الأدمن المتميّزة) دالة Edge
├── docs/email-templates/ ← README + ١٠ قوالب بريد عربية
├── .github/workflows/    ← backup.yml, deploy.yml, keep-alive.yml (راجع القسمين ٤ و ١١)
├── sydent/               ← مهجور - ليس الإنتاج (راجع القسم ١١) Next.js هيكل
├── server.js, package.json ← قديم - ليس الإنتاج (راجع القسم ١١) Express خادم
└── theme-classic-backup.css, sidebar-classic-backup.js ← نسخ استرجاع ما قبل إعادة التصميم
  
```

index (اللوحة), auth, reset-password, landing, pending, patients, patient-profile, appointments, treatments, inventory, labs, expenses, doctors, employees, payouts, provider-reports, accounting, audit-log, subscription, settings, admin (المنصة), book (الحجز العام).

٤. كيف يعمل النشر

1. اعمل push لـ commit على main في GitHub.
2. Cloudflare Pages بيكتشف الـ push وينشر الملفات الساكنة تلقائياً على sydent.app. بدون بناء، بدون أي إجراء يدوي.

قاعدة كسر الكاش (Cache-busting)

بما إنو ما في bundler، الملفات المشتركة بتُرقم بـ query string [حرف] ?v=YYYYMMDD على وسوم <script> / <link>. التوكن الحالي: 20260624a.

لما تغيّر ملف مشترك (supabase-init.js , sidebar.js , theme.css/js , timepicker.js), لازم ترفع التوكن في كل ملفات HTML ما عدا book.html ، حتى يجلب المتصفح النسخة الجديدة. هاد حالياً يُعمل يدوياً — أتمتته من المهام المعروفة (القسم ٩).

keep-alive.yml

الخطة المجانية لـ Supabase بتنمّ المشروع بعد ٧ أيام بلا أي استعلام، والمجانية بلا نسخ احتياطي تلقائي، فالمشروع النائم خطر. هالـ workflow بيعمل ping على REST API مرتين بالأسبوع ليعطي المشروع صاحياً خلال فترة ما قبل الإطلاق. المفتاح اللي بيستعمله هو المفتاح العام (anon) (مو سرّ). خليه شغلاً حتى الإطلاق.

٥. قاعدة البيانات والترحيلات (Migrations) — اقرأ هالقسم بتمعن

مصدر الحقيقة = مخطط قاعدة البيانات الحيّ في Supabase، وليس ملفات الترحيلات.

مجلد migrations/ فيه ٦٠ ملف SQL، لكنه سجلّ تاريخي جزئي. خلال التطوير، كثير من تغييرات المخطط طُبقت مباشرة في محرّر SQL بـ Supabase ووُثقت كملفات أحياناً فقط. أرقام الترحيلات فيها فجوات (مثلاً ١١، ١٢، ١٧-٢٣ بلا ملفات) وبعض الأرقام أُعيد استخدامها. لا تفترض أن الملفات تعيد إنتاج المخطط الحيّ. لو احتجت تجهيز بيئة جديدة، اسحب المخطط من قاعدة البيانات الحيّة بدل إعادة تشغيل هالملفات.

حالة الترحيلات المؤكّدة (تم التحقق ٢٧ حزيران ٢٠٢٦ باستعلام حيّ)

آخر ثلاثة ترحيلات كانت موضع تساؤل — كلها مطبّقة:

الترحيل	شو بيضيف	مطبّق؟
٧٠	علم <code>clinic_settings.treatments_seeded</code>	true ✓
٧١	<code>inventory_items.expiry_date</code>	true ✓
٧٢	جدول <code>inventory_batches</code> (دفعات لكل شحنة، FEFO)	true ✓

لا يوجد أي ترحيل معلق عند التسليم. رقم ملف الترحيل التالي هو ٧٣.

حقائق مشروع Supabase

- معرّف المشروع (ref): `rycqzpdhxabpqrddtdzg` (المنطقة: EU).
- حاوية التخزين `patient-files` فيها مستندات/صور المرضى، محمية بـ RLS.
- دالة Edge واحدة `admin-ops` فيها كل العمليات المتميزة (service-role) على الخادم — مفتاح `service-role` يجب ألا يصل المتصفح أبداً (أزيل عمداً من `admin.html`).

٦. الأسرار والمفاتيح — دورها كلها قبل أول عميل

لا توجد قيم أسرار حقيقية في هذه الوثيقة ولا في الريبو، بشكل مقصود. أدناه مكان كل سرّ ووظيفته. بما أن المالك الأصلي غير مبرمج وأن المفاتيح سُوركت مع أدوات الذكاء الاصطناعي خلال التطوير، يجب على المبرمج الجديد تدوير كل سرّ مذكور هنا قبل استقبال أي عميل حقيقي.

أسرار GitHub (الريبو ← Actions ← Secrets and variables ← Settings) — ٧ أسرار

السرّ	الوظيفة
<code>SUPABASE_DB_URL</code>	سلسلة اتصال قاعدة البيانات للنسخ الاحتياطي اليومي
<code>BACKUP_PAT</code>	توكن fine-grained مقصور على ريبو النسخ الاحتياطي فقط
<code>/ SUPABASE_S3_ACCESS_KEY_ID</code> <code>SUPABASE_S3_SECRET_ACCESS_KEY</code>	قراءة ملفات المرضى من تخزين Supabase (بروتوكول S3)
<code>/ R2_SECRET_ACCESS_KEY / R2_ACCESS_KEY_ID</code> <code>R2_ACCOUNT_ID</code>	كتابة نسخ ملفات المرضى إلى Cloudflare R2

بالإضافة لمتغيّر repo اسمه `BACKUP_ENABLED` (لازم يكون `true` ليشتغل النسخ الاحتياطي).

مفاتيح أخرى (مخزنة خارج الريبو، في ملاحظات المالك الخاصة)

- **GitHub PAT** لدفع الكود (حالياً توكن least-privilege اسمه `SyDent-dev` ، مقصور على الريبو، ينتهي حيزان ٢٠٢٧). ولّد توكن خاص فيك وألغ هذا.
- **مفتاح Supabase العام (anon/publishable)** — عام بالتصميم، موجود في `supabase-init.js` . آمن للكشف (الحماية الفعلية هي RLS). لا يحتاج تدوير، بس افهم ليش هو آمن.
- **مفتاح Supabase service-role** — متميّز؛ موجود فقط في بيئة دالة `admin-ops` (Deno.env). لا تضعه أبداً في كود الواجهة.
- **مفتاح Resend API** — يُستخدم ككلمة سرّ SMTP في إعدادات Supabase Auth. دورّه وأعد إدخاله.
- **حساب Cloudflare** — DNS + Pages + R2 + Turnstile

CAPTCHA (Cloudflare Turnstile) — مفعّل أصلاً

- مفتاح الموقع `0x4AAAAAADr7FjcBLQHJKhcS` عام بالتصميم، مكتوب في `auth.html` + `settings.html` (٤) نقاط: الدخول، التسجيل، نسيت كلمة المرور، إعادة التحقق عند حذف الحساب).
- المفتاح السريّ لـ Turnstile موجود فقط في (Supabase (Authentication ← Attack Protection). دورّه لو أعدت توليد widget.

٧. النسخ الاحتياطي والاستعادة

- **قاعدة البيانات:** GitHub Actions `backup.yml` يشتغل يومياً (الساعة ٢ صباحاً)، يأخذ نسخة من القاعدة (الأدوار + المخطّط + البيانات، بما فيها مخطّط `auth` فحسابات الدخول محفوظة) إلى الريبو الخاص - `AyhamGhnaim/SyDent` `backups` بمجلد مؤرّخ.
- **ملفات المرضى:** تُزامن يومياً من تخزين Supabase (`patient-files`) إلى حاوية Cloudflare R2 اسمها `sydent-backups` عبر `rclone` (نفس workflow).
- **الاستعادة:** موثّقة بشكل منفصل في `SyDent_DR_Runbook.md` (ضمن ملفات سياق المالك). لم يُجرَ اختبار استعادة كامل حتى الآن — اعمله مبكراً كمالك جديد للتأكد أن النسخ قابلة للاستعادة فعلاً.

٨. المراقبة

- **التوفّر (Uptime):** BetterStack — مونيتوران (`sydent.app` كل ٥ دقائق، `book.html` كل ٣ دقائق)، تنبيهات إيميل + SMS.
- **أخطاء JS:** Sentry browser SDK محمّل على كل الصفحات الـ ٢٢ (منطقة EU، أخطاء فقط). خطأ اختبار متبقي اسمه `SYDENT-WEB-1` يُفضّل حلّه من لوحة Sentry (تجميلي).
- **ضبط التكلفة:** سقف الإنفاق في Supabase مفعّل (لا فواتير مفاجئة) + تنبيه إيميل تلقائي عند ٢٠٪ من أي حد.

٩. خارطة تصليب ما قبل الإطلاق (المحاور الستة)

نظم المالك العمل المتبقي ضمن ستة محاور. حالتها عند التسليم:

المحور	الحالة	ملاحظات
١. التعافي من الكوارث	✓ مكتمل	نسخ يومية للقاعدة + ملفات المرضى. اختبار الاستعادة لسا معلق.
٢. المراقبة	✓ مكتمل	BetterStack + Sentry + تنبيهات Supabase شغالة.
٣. أمان الإطلاق	▲ شبه مكتمل	نمط تدوير الأسرار + CAPTCHA + البريد المخصص كلها تمت. تدرج DMARC وتدوير المفاتيح لسا متبقيان (القسم ١٠).
٤. نظافة الكود	▲ لم يبدأ	تصليب XSS، انتهاء PAT النسخ الاحتياطي، إلخ. (القسم ١٠)
٥. الأتمتة	▲ لم يبدأ	سكربت كسر-كاش بأمر واحد؛ خُرّاس CI. (القسم ١٠)
٦. التوثيق / عامل الباص	▲ جارٍ	هذه الوثيقة جزء من المحور ٦.

١٠. العمل المتبقي — مصنفًا

● إلزامي قبل أول عميل حقيقي

١. **دور كل الأسرار** (القسم ٦). شُوركت مع أدوات ذكاء اصطناعي خلال التطوير. يشمل GitHub PAT، مفتاح Resend API، مفتاح Supabase service-role، ومفاتيح S3/R2 للنسخ الاحتياطي.
٢. **درج DMARC**. البريد شغّال عبر Resend؛ DMARC حالياً على `p=none` (مراقبة فقط) في سجل DNS `_dmarc.mail.sydent.app`. بعد التأكد أن تقارير DMARC تُظهر مرور كل البريد الشرعي، شدّد إلى `p=quarantine` ثم `p=reject` (سجل TXT في Cloudflare DNS). هذا يمنع انتحال بريدك أو وقوعه في السبام.
٣. **قرار سعة البريد**. حدّ معدّل بريد Supabase Auth مضبوط على `٤/ساعة` ليُطابق الخطة المجانية لـ Resend (١٠٠/يوم). كافٍ لعدد قليل من العيادات لكنه سيخنق التسجيل المتزامن عند التوسّع. قبل استقبال عملاء كثر، رُقّ Resend Pro (≈ \$٢٠/شهر = ٥٠ ألف إيميل) وارفع حدّ معدّل Supabase.
٤. **اعمل اختبار استعادة نسخة احتياطية** (القسم ٧) — لم يُجرَ أبداً.

▲ تحسينات / قرارات

- **منطقة Resend**: حالياً US East (منطقة EU كانت تحتاج خطة مدفوعة وقت الإعداد). أعد النظر لو يهّم زمن الوصول/الامتثال.
- **نفق Sentry**: حاجبات الإعلانات (مثل Brave) تحجب CDN تبع Sentry؛ تمرير الأحداث عبر نطاق SyDent يعطي تغطية أخطاء ١٠٠٪. اختياري.

• `admin.html` يستخدم `alert()` ~١٥١ مرة — يعمل، لكن تحويله لإشعارات toast تجميل اختياري.

نظافة الكود / التنظيف

- PAT النسخ الاحتياطي `sydent-backup` بلا تاريخ انتهاء — استبدله بتوكن least-privilege ينتهي بتاريخ.
- H2 (XSS نظري): أسماء المرضى تُدمج في template literals بـ `appointments.html` (`renderList` / `renderDay`). مسارات العرض الأخرى تهزّب عبر `escapeHtml` ؛ هاتان النقطتان تحتاجان تدقيقاً وتصليباً. خطر نظري؛ لا استغلال معروف.
- حلّ خطأ الاختبار `SYDENT-WEB-1` في Sentry (تجميل).
- ملفات قديمة للمراجعة/الإزالة (راجع القسم ١١).

الأتمتة (المحور ٥)

- سكربت واحد لرفع توكن كسر-الكاش عبر كل ملفات HTML (حالياً يدوي عبر ~٢١ ملف).
- حُرّاس CI للثوابت التطويرية (فحص صياغة JS، توازن div، ترتيب CDN، فحص الأسرار) التي كانت تُشغّل يدوياً خلال التطوير.

اختبارات حيّة متبقّية (مخاطرة منخفضة، تأكيد سلوك فقط)

- زرع الترحيل ٧٠ التلقائي: حساب فارغ جديد ← صفحة العلاجات ← القائمة الافتراضية تُملاً تلقائياً بسعر ٠.
- شريط انقطاع النت: Offline ← Network ← DevTools ← يظهر شريط أحمر؛ Online ← يختفي.
- اختبار "Bug #1" (مدير تحويل الدخل): يحتاج سيناريو عدم حضور حقيقي + دفعة غير مكتسبة.

١١. نظافة الريبو — ملفات قديمة / غير إنتاجية (راجع، لا تفترض)

موجودة بالريبو لكنها ليست جزءاً من المنتج الشغّل. راجعها وغالباً احذفها:

1. مجلد `sydent/` — هيكل Next.js مهجور (`page.tsx` / `layout.tsx` افتراضية، `CLAUDE.md` ، `AGENTS.md`). يبدو محاولة إعادة كتابة تجريبية لم تُعتمد. الإنتاج هو HTML الصّرف بالجزر.
2. `server.js` + `package.json` ("sydent-server") — خادم Express قديم لتحديث الملفات عبر GitHub API. في تبويب خدمة Render بمتصفّح المالك مرتبط فيه. كان آلية تحرير قديمة؛ لا يستخدمه الموقع الساكن المباشر. تأكّد من سلامة إيقافه.
3. `github/workflows/deploy.yml` — workflow قديم "Deploy to GitHub Pages" يدوس `index.html` عبر `workflow_dispatch` بهويّة بوت ("DentSyr Bot" / "Update via Claude"). النشر الحقيقي هو Cloudflare Pages — هذا workflow ميت وخطير لو شغّل (سيدوس `index.html`). يُنصح بحذفه بعد التأكد. (workflow يتيم مشابه أُزيل سابقاً خلال التطوير).
4. ملفات متناثرة بالجزر: `49_subscription_events_append_only.sql` ، `rls_audit_diagnostic.sql` ، `rls_audit_unified.sql` ، `context_delta_v78.md` — آثار تطوير بالجزر؛ انقلها لمجلد أو احذفها.

١٢. المشاكل المعروفة (حزمة "H")

- H1 — خيار ناقص في قائمة حالة منسدلة؛ بالتصميم بعد تراجع مقصود (لا يحتاج إصلاح).
 - H2 — XSS نظري في template literals لأسماء المرضى (راجع تنظيف القسم ١٠).
 - H3 — كاش المرضى قد يكون قديماً بعد إضافة مريض جديد بلا إعادة تحميل (مخفف بعلم تحديث).
 - H4 — موعد لاحق اليوم يُصنّف أحياناً "قريب" بدل "متأخر" في أحد مصنّفات التذكير.
- ما في شي حاجب؛ H2 هو الوحيد ذو الصلة الأمنية.

١٣. مفاهيم أساسية في النطاق (حتى لا تكسر المالية)

- **المحاسبة على الأساس النقدي.** "split" الدفعة يُحتسب إيراداً مكتسباً فقط إذا كان `is_unearned = false` و مرتبطاً بجلسة مكتملة. توجد ثوابت حفظ (conservation invariants) واختبار ذاتي مدمج (Ctrl+Shift+D) على أسطح المحاسبة).
- **منطق المالية/المحاسبة هو أكثر جزء حساس في النظام.** دقق بعمق. لا تعدّله بدون تحليل عميق — منطق توزيع الدفعات (FIFO) مكرّر عبر ثلاثة ملفات (`patient-profile.html` ، `appointments.html` ، `settings.html`) ولازم يبقوا متطابقين. مسار الحفظ الذري يمرّ عبر `realloc_patient_splits` RPC.
- **نموذج الأمان:** RLS لكل مستأجر (`owner_id = auth.uid()`). `book.html` هو السطح المجهول الوحيد ويكتب فقط عبر ثلاث دوال `SECURITY DEFINER` بحدود إساءة؛ جدولته غير ذلك `deny-all` للمجهولين.

١٤. أعراف التطوير المتّبعة حتى الآن

لو أكملت بنفس الأسلوب الصّرف:

- عدّل ملف `book.html` / `js`. المستهدف مباشرة؛ `push` لـ `main` : Cloudflare Pages ينشر.
- بعد تغيير ملف مشترك، ارفع توكن كسر-الكاش في كل مكان ما عدا `book.html`.
- `book.html` لا يُمسّ أبداً في عمليات التعديل الجماعية.
- الترحيلات تُطبّق في محرّر SQL بـ Supabase؛ احفظ الـ SQL كملف مرقّم في `migrations/` للسجلّ.
- احتفظ المالك بملف سياق تفصيلي جارٍ (`SyDent_Context_knew_md_*.md`) و"قواعد" مرقّمة (#١-#١٩١) تلتقط كل درس مكتسب. **ملفات السياق هذه هي المرجع الأعمق** — اطلبها من المالك؛ فيها التاريخ الكامل، كل المطبّات، ومنطق كل قرار معماري. هي عمداً **غير مُودعة في git** (فيها مفاتيح).

١٥. قائمة فحص الأسبوع الأول للمبرمج الجديد

1. احصل على الوصول: ريبو GitHub، مشروع Supabase، حساب Sentry، BetterStack، Resend، Cloudflare.

2. اقرأ ملف سياق المالك `SyDent_Context_knew_md_*.md` من البداية للنهاية.
 3. **دور كل سر** (القسم ٦) وحدّث أسرار GitHub + Supabase + Cloudflare وفقاً لذلك.
 4. **اعمل اختبار استعادة نسخة احتياطية** في مشروع Supabase مؤقّت (القسم ٧).
 5. اسحب مخطّط القاعدة الحيّ كأساس حقيقي (القسم ٥).
 6. افرز ملفات القسم ١١ القديمة (احذف `deploy.yml` ، قرّر بشأن `sydent/` و `server.js`).
 7. خطّط لتدرّج DMARC + سعة البريد (القسم ١٠) قبل أول عميل.
-

نهاية الوثيقة. منتج مباشر، HEAD نظيف `3992bf6` ، لا ترحيلات معلّقة، صفر عملاء حقيقيين. النظام يعمل؛ ما تبقى هو التصليب الاحترافي قبل الإطلاق.